



# PHISHING AWARENESS & CYBER HYGIENE TRAINING

IDENTIFYING SOCIAL ENGINEERING · SECURING CREDENTIALS · PREVENTING CYBER THREATS

---

**Presented by: MD. Rejone Hossen Riaz**

Cybersecurity Intern | CodeAlpha

# Understanding Phishing Attacks

Phishing is a social engineering attack where malicious actors deceive users into handing over sensitive credentials, personal information, or access to secure networks by masquerading as trusted organizations.



## Email Phishing

Bulk deceptive emails delivered to broad recipient lists.



## Spear Phishing

Context-specific attacks targeted at chosen individuals or organizations.



## Smishing & Vishing

Exploitative attacks leveraging SMS messages and fraudulent phone calls.



## Clone Phishing

Duplicating legitimate past interactions and substituting safe links or attachments with malicious files.



# Psychological Exploitations in Social Engineering

Attackers deliberately manipulate human emotions and decision-making heuristics to bypass critical analysis.



## Manufactured Urgency

Imposing severe time constraints (e.g., "Account lockout in 60 minutes") to trigger hasty actions.



## Authority Impersonation

Posing as department heads, IT security teams, law enforcement, or executive leadership.



## Intimidation & Fear

Threats of regulatory fines, termination, or compromised confidential assets.



## Greed & Curiosity

Promising unearned cash rewards, lottery bonuses, or package deliveries.

# Critical Email Red Flags

Identifying anomalous elements within deceptive emails allows swift threat neutralization.



## Deceptive Sender Domains

Display names matching trusted entities while the underlying domain is fraudulent.

`support@paypal-update.com`



## Impersonal Salutations

Generic greetings such as "Dear Customer" instead of a verified username or personal name.



## Misleading Hyperlinks

Embedded anchor text masking an entirely disparate, suspicious target URL.



## High-Risk Attachments

Inclusions carrying executable or macro-enabled formats.

`.exe · .scr · .iso · .docm`

# Spotting Fake Login Portals

Threat actors build identical login interfaces to intercept plain-text credentials and session tokens.

 `https://netflx.com/login`

## Padlock ≠ Authenticity

HTTPS/SSL confirms the connection is encrypted — not that the destination domain is genuine.



Typosquatted domains and mismatched TLDs mimic trusted brands pixel-for-pixel.



## Typosquatting

Domain names registered with deliberate typographic errors.

`netflx.com` · `g00gle.com`



## Padlock Misconception

HTTPS/SSL confirms encrypted data flow, not domain authenticity.



## Broken UI Elements

Low-resolution brand assets, distorted alignment, grammatical inconsistencies.



## High-Risk TLDs

Unconventional top-level domains used to mimic corporate login infrastructure.

`.xyz` · `.top` · `.info`

# Real-World Incident: SSO Credential Harvesting

Examining how single-point phishing campaigns lead to broad enterprise compromises.



# Core Cyber Hygiene & Defense Guidelines

Foundational mitigation protocols every user and enterprise must implement.



## Multi-Factor Authentication

Deploy hardware keys or app-based authenticator codes to prevent password-only breaches.



## Out-of-Band Validation

Verify unusual requests via direct, pre-authenticated secondary communication channels.



## Dedicated Password Managers

Systems verify actual browser URLs before enabling autofill operations.



## Link Inspection Discipline

Consistently inspect URLs by hovering before committing any interaction.



## Immediate Incident Escalation

Promptly report suspicious communications directly to the internal security team.

# Security Knowledge Assessment



## SCENARIO

You receive an urgent email from your "Executive Board" requesting a confidential spreadsheet download via an unverified cloud drive link.

**A**

Complete the download immediately to prevent operational bottlenecks.

**B**

Open the link inside private browsing mode to test its contents safely.

**C**

Disregard the message and alert coworkers to avoid opening it.

**D**

Halt interaction, inspect the sender domain, and verify via authorized channels while alerting security.



# Building a Resilient Security Posture

Individual user awareness is the most critical perimeter defense across modern network architectures.



Human vigilance stops what perimeter filters occasionally fail to intercept.



When facing anomalous communications: Pause, verify sender authenticity, and inspect endpoints.



Early detection and reporting protect the entire organizational network.

**"THINK BEFORE YOU CLICK"**

Project by: MD. Rejone Hossen Riaz

CodeAlpha